Brotli decoder Exposure & inventory report

CVE-2026-111497 · rules 2026-10-25 · generated 2026-10-26T01:27:04+00:00

> Version evidence requires verification. Exploitability is always `not_tested`. A fixed version report is not a safety guarantee. HTTP/2 and Brotli response headers do not establish vulnerable decoding. Report complete: True.

2	1	2	1
potentially affected	unsupported runtime	unknown	fixed version reported

Coverage & unknowns

6 component observations. 0 operational errors. No exhaustive discovery or reachability verification.

- No exhaustive discovery of installed, loaded, bundled or deployed copies.
- Red Hat and other unimplemented vendor builds require exact vendor errata; no generic distribution comparison.
- Python versions below the shared advisory lower bound remain disputed and unknown.
- Envoy older patches not explicitly named in its advisory remain unknown.
- curl/libcurl and cdxgen product versions are not mapped to their bundled decoder/runtime.
- Synthetic partial export; no targets contacted and no loaded-code attestation

Component assessments

API.EXAMPLE.COM / PYTHON-WORKER

potentially affected

python-brotli `1.2.0`

reported version in affected interval · Fix: `1.2.1`

Verify the exact deployed package and vendor advisory. Upgrade to a fixed maintained release; rebuild bundled artifacts/images, redeploy, restart, and verify the running component. Review inbound requests, outbound responses and direct decoding independently.

▼ Evidence and limitations

evidence origin	installed_metadata
ecosystem	PyPI
package	brotli
build source	unknown
vendor	unknown
release	
linkage	bundled
loaded	unknown
decoder	capability not independently verified
configuration	unknown
reachability	outbound response decoding requires review
mitigation	unknown
patch evidence	unknown
versions	not supplied
brotli version	not supplied
brotli decompress available	not supplied
brotli block switch error	not supplied
observed at	2026-10-25T20:00:00Z

- Reported metadata does not attest deployed patches or decoder reachability.

Authoritative advisory · Exploitability: `not_tested`

GATEWAY.EXAMPLE.COM / ENVOY-PROXY

potentially affected

envoy 1.39.2

reported version in affected interval · Fix: `1.39.3`

Verify the exact deployed package and vendor advisory. Upgrade to a fixed maintained release; rebuild bundled artifacts/images, redeploy, restart, and verify the running component. Review inbound requests, outbound responses and direct decoding independently.

▼ Evidence and limitations

evidence origin	operator_inventory
ecosystem	proxy
package	
build source	unknown
vendor	unknown
release	
linkage	unknown
loaded	unknown
decoder	unknown
configuration	Brotli decompressor reported enabled
reachability	unknown
mitigation	unknown
patch evidence	unknown
versions	not supplied
brotli version	not supplied
brotli decompress available	not supplied
brotli block switch error	not supplied
observed at	2026-10-25T20:00:00Z

- Reported metadata does not attest deployed patches or decoder reachability.

Authoritative advisory · Exploitability: `not_tested`

LEGACY.EXAMPLE.COM / NODE-LEGACY

node 20.19.0

unsupported runtime

unsupported node line not cve confirmation · Fix: `requires review`

Verify the exact deployed package and vendor advisory. Upgrade to a fixed maintained release; rebuild bundled artifacts/images, redeploy, restart, and verify the running component. Review inbound requests, outbound responses and direct decoding independently.

▼ Evidence and limitations

evidence origin	installed_metadata
ecosystem	runtime
package	
build source	unknown
vendor	unknown
release	
linkage	unknown
loaded	unknown
decoder	unknown
configuration	unknown
reachability	unknown
mitigation	unknown
patch evidence	unknown
versions	not supplied
brotli version	not supplied
brotli decompress available	not supplied
brotli block switch error	not supplied
observed at	2026-10-25T20:00:00Z

- Reported metadata does not attest deployed patches or decoder reachability.

Authoritative advisory · Exploitability: `not_tested`

BATCH.EXAMPLE.COM / DECLARED-ONLY

brotlicffi `1.2.1.0`

unknown

declaration not installed evidence · Fix: `requires review`

Verify the exact deployed package and vendor advisory. Upgrade to a fixed maintained release; rebuild bundled artifacts/images, redeploy, restart, and verify the running component. Review inbound requests, outbound responses and direct decoding independently.

▼ Evidence and limitations

evidence origin	declared
ecosystem	PyPI
package	
build source	unknown
vendor	unknown
release	
linkage	unknown
loaded	unknown
decoder	unknown
configuration	unknown
reachability	unknown
mitigation	unknown
patch evidence	unknown
versions	not supplied
brotli version	not supplied
brotli decompress available	not supplied
brotli block switch error	not supplied
observed at	2026-10-25T20:00:00Z

- Reported metadata does not attest deployed patches or decoder reachability.

Authoritative advisory · Exploitability: `not_tested`

WORKER.EXAMPLE.COM / VENDOR-CUSTOM

node 24.22.1

unknown

vendor custom or patch provenance requires review · Fix: `requires review`

Verify the exact deployed package and vendor advisory. Upgrade to a fixed maintained release; rebuild bundled artifacts/images, redeploy, restart, and verify the running component. Review inbound requests, outbound responses and direct decoding independently.

▼ Evidence and limitations

evidence origin	operator_inventory
ecosystem	runtime
package	
build source	custom
vendor	unknown
release	
linkage	unknown
loaded	unknown
decoder	unknown
configuration	unknown
reachability	unknown
mitigation	unknown
patch evidence	unknown
versions	not supplied
brotli version	not supplied
brotli decompress available	not supplied
brotli block switch error	not supplied
observed at	2026-10-25T20:00:00Z

- Reported metadata does not attest deployed patches or decoder reachability.

Authoritative advisory · Exploitability: `not_tested`

API.EXAMPLE.COM / NATIVE-FIXED-COPY

brotli 1.1.1

fixed version reported

reported version meets branch fix · Fix: 1.1.1

Verify the exact deployed package and vendor advisory. Upgrade to a fixed maintained release; rebuild bundled artifacts/images, redeploy, restart, and verify the running component. Review inbound requests, outbound responses and direct decoding independently.

▼ Evidence and limitations

evidence origin	installed_metadata
ecosystem	native
package	
build source	unknown
vendor	unknown
release	
linkage	system
loaded	unknown
decoder	unknown
configuration	unknown
reachability	unknown
mitigation	unknown
patch evidence	unknown
versions	not supplied
brotli version	not supplied
brotli decompress available	not supplied
brotli block switch error	not supplied
observed at	2026-10-25T20:00:00Z

- Reported metadata does not attest deployed patches or decoder reachability.

Authoritative advisory · Exploitability: `not_tested`

Branch-specific fixes

Product	Branch → fix
node	22 → 22.23.4; 24 → 24.22.1; 26 → 26.12.1

Product	Branch → fix
brotli	1.0 → 1.0.10; 1.1 → 1.1.1; 1.2 → 1.2.1
envoy	1.36 → 1.36.12; 1.37 → 1.37.8; 1.38 → 1.38.6; 1.39 → 1.39.3; 1.40 → 1.40.0
istio	1.29 → 1.29.9; 1.30 → 1.30.6; 1.31 → 1.31.2
Python Brotli / brotlicffi	1.2.1 / 1.2.1.0; disputed older ranges remain unknown
Bun / Brotli4j	1.4.4 / 1.24.0 within covered major 1
Debian	Exact source-package/release matches only; see each result

Verify the running application

Verify the exact deployed package and vendor advisory. Upgrade to a fixed maintained release; rebuild bundled artifacts/images, redeploy, restart, and verify the running component. Review inbound requests, outbound responses and direct decoding independently. For incoming bodies, reject Brotli before decoding. For outbound requests, disable automatic Brotli response decoding or reject it before body processing; changing Accept-Encoding alone is insufficient. Mitigations do not change patch status.
